

Threat Hunt Lab 1: Devices Accidentally Exposed to the Internet

1. Preparation

- **Goal:** Set up the hunt by defining what you're looking for.
 - During routine maintenance, the security team is tasked with investigating any VMs in the shared services cluster (handling DNS, Domain Services, DHCP, etc.) that have mistakenly been exposed to the public internet. The goal is to identify any misconfigured VMs and check for potential brute-force login attempts/successes from external sources.
- **Activity:** Develop a hypothesis based on threat intelligence and security gaps (e.g., "Could there be lateral movement in the network?").
 - During the time the devices were unknowingly exposed to the internet, it's possible that someone could have actually brute-force logged into some of them since some of the older devices do not have account lockout configured for excessive failed login attempts.

2. Data Collection

- **Goal:** Gather relevant data from logs, network traffic, and endpoints.
 - Consider inspecting the logs to see which devices have been exposed to the internet and have received excessive failed login attempts. Take note of the source IP addresses and number of failures, etc.
- **Activity:** Ensure data is available from all key sources for analysis.
 - Ensure the relevant tables contain recent logs:
 - ◆ DeviceInfo
 - ◆ DeviceLogonEvents

3. Data Analysis

- **Goal:** Analyze data to test your hypothesis.
- **Activity:** Look for anomalies, patterns, or indicators of compromise (IOCs) using various tools and techniques.
 - Is there any evidence of brute force success (many failed logins followed by a success?) on your VM or ANY VMs in the environment?
 - If so, what else happened on that machine around the same time? Were any bad actors able to log in?

4. Investigation

- **Goal:** Investigate any suspicious findings.
- **Activity:** Dig deeper into detected threats, determine their scope, and

escalate if necessary. See if anything you find matches TTPs within the [MITRE ATT&CK Framework](#).

- You can use ChatGPT to figure this out by pasting/uploading the logs:
- [Scenario 1: TTPs](#)

Timestamp	DeviceId	DeviceName	ActionType
Oct 3, 2024 4:07:28 PM	e0c3ea6432b04 90c30064f05a9 35fbac267bd697	ms-edr	LogonFailed
Oct 3, 2024 4:07:28 PM	e0c3ea6432b04 90c30064f05a9 35fbac267bd697	ms-edr	LogonFailed
Oct 3, 2024 4:12:29 PM	e0c3ea6432b04 90c30064f05a9 35fbac267bd697	ms-edr	LogonFailed
Oct 3, 2024 4:12:29 PM	e0c3ea6432b04 90c30064f05a9 35fbac267bd697	ms-edr	LogonFailed

Which TTPs in the MITRE ATT&CK framework do these logs appear to correlate to?

ChatGPT said:

ChatGPT

The new log file contains entries related to failed login attempts, with fields such as timestamps, device IDs, action types (like "LogonFailed"), account names, protocols (such as NTLM), and failure reasons (like "InvalidUserNameOrPassword").

Given the details in this log file, the following MITRE ATT&CK TTPs are relevant:

1. T1078 - Valid Accounts:

- The "LogonFailed" events, particularly with NTLM and failure reasons such as "InvalidUserNameOrPassword," suggest attempts to authenticate using potentially valid but incorrect credentials. This aligns with the adversary tactic of using compromised or valid accounts to attempt unauthorized access.

2. T1110 - Brute Force:

- Repeated failed login attempts, especially with different account names (e.g., "administrator," "trhodes," "sross"), indicate possible brute-force attempts. This tactic involves attempting to guess account passwords to gain access.

3. T1040 - Network Sniffing:

- NTLM is a network authentication protocol, and the presence of this protocol in the logs may indicate attempts to capture or sniff

credentials in transit, especially in conjunction with failed login attempts.

4. **T1556.002 - Multi-factor Authentication (MFA) Interception:**

- If these logs come from a system where MFA is implemented but not correctly handled, repeated failed logins could be an attempt to bypass or intercept MFA mechanisms.

5. **T1212 - Exploitation of Remote Services:**

- If these logs involve remote login attempts (indicated by "IsLocalLogon: false"), it suggests an adversary trying to exploit remote services by brute-forcing or leveraging valid accounts to gain unauthorized access.

If you have more specific contexts about the environment or additional fields in the logs, we could further refine these correlations to particular sub-techniques.

5. Response

- **Goal:** Mitigate any confirmed threats.
- **Activity:** Work with security teams to contain, remove, and recover from the threat.
 - Can anything be done?

6. Documentation

- **Goal:** Record your findings and learn from them.
- **Activity:** Document what you found and use it to improve future hunts and defenses.
 - Document what you did

7. Improvement

- **Goal:** Improve your security posture or refine your methods for the next hunt.
- **Activity:** Adjust strategies and tools based on what worked or didn't.
 - Anything we could have done to prevent the thing we hunted for? Any way we could have improved our hunting process?

Notes / Findings:

Sample Queries (spoilers, highlight or copy/paste to reveal):

```
// Check most failed logons
```

```
DeviceLogonEvents
```

```
| where LogonType has_any("Network", "Interactive", "RemoteInteractive",
```

```

"Unlock")
| where ActionType == "LogonFailed"
| where isnotempty(RemoteIP)
| summarize Attempts = count() by ActionType, RemoteIP, DeviceName
| order by Attempts

// Take the top 10 IPs with the most logon failures and see if any succeeded to
logon
let RemoteIPsInQuestion = dynamic(["119.42.115.235","183.81.169.238",
"74.39.190.50", "121.30.214.172", "83.222.191.62", "45.41.204.12",
"192.109.240.116"]);
DeviceLogonEvents
| where LogonType has_any("Network", "Interactive", "RemoteInteractive",
"Unlock")
| where ActionType == "LogonSuccess"
| where RemoteIP has_any(RemoteIPsInQuestion)

// Look for any remote IP addresses who have had both successful and failed
logons
// Investigate for potential brute force successes
let FailedLogons = DeviceLogonEvents
| where LogonType has_any("Network", "Interactive", "RemoteInteractive",
"Unlock")
| where ActionType == "LogonFailed"
| where isnotempty(RemoteIP)
| summarize FailedLogonAttempts = count() by ActionType, RemoteIP,
DeviceName
| order by FailedLogonAttempts;
let SuccessfulLogons = DeviceLogonEvents
| where LogonType has_any("Network", "Interactive", "RemoteInteractive",
"Unlock")
| where ActionType == "LogonSuccess"
| where isnotempty(RemoteIP)
| summarize SuccessfulLogons = count() by ActionType, RemoteIP,
DeviceName, AccountName
| order by SuccessfulLogons;
FailedLogons
| join SuccessfulLogons on RemoteIP
| project RemoteIP, DeviceName, FailedLogonAttempts, SuccessfulLogons,
AccountName

```

Timeline Summary and Findings:

Windows-target-1 has been internet for several for several days:

DeviceInfo

```
| where DeviceName == "windows-target-1"  
| where IsInternetFacing == true  
| order by Timestamp desc
```

Last internet facing time: 2024-10-18T01:37:49.6475189Z

Several bad actors have been discovered attempting to log into the target machine

// Check most failed logons

DeviceLogonEvents

```
| where LogonType has_any("Network", "Interactive", "RemoteInteractive",  
"Unlock")  
| where ActionType == "LogonFailed"  
| where isnotempty(RemoteIP)  
| summarize Attempts = count() by ActionType, RemoteIP, DeviceName  
| order by Attempts
```

Filters: Add filter				
☐	ActionType	RemoteIP	DeviceName	Attempts
☐	> LogonFailed	(ip) 78.142.18.85	🖥 windows-target-1	235
☐	> LogonFailed	(ip) 94.232.43.105	🖥 windows-target-1	114
☐	> LogonFailed	(ip) 211.250.217.139	🖥 windows-target-1	59
☐	> LogonFailed	(ip) 194.169.175.13	🖥 windows-target-1	40
☐	> LogonFailed	(ip) 141.98.11.142	🖥 windows-target-1	40
☐	> LogonFailed	(ip) 4.184.136.102	🖥 windows-target-1	38
☐	> LogonFailed	(ip) 14.225.23.169	🖥 windows-target-1	29
☐	> LogonFailed	(ip) 121.157.251.4	🖥 windows-target-1	26
☐	> LogonFailed	(ip) 91.203.60.30	🖥 windows-target-1	24
☐	> LogonFailed	(ip) 81.19.135.47	🖥 windows-target-1	21

The top most failed login attempt IP address have not bee able to successfully break into the VM

// Take the top 10 IPs with the most logon failures and see if any succeeded to logon

```
let RemoteIPsInQuestion = dynamic(["119.42.115.235","183.81.169.238",
"74.39.190.50", "121.30.214.172", "83.222.191.62", "45.41.204.12",
"192.109.240.116"]);
```

DeviceLogonEvents

```
| where LogonType has_any("Network", "Interactive", "RemoteInteractive",
"Unlock")
```

```
| where ActionType == "LogonSuccess"
```

```
| where RemoteIP has_any(RemoteIPsInQuestion)
```

<Query no results>

The only successful remote/network logons in the last 30 days was for the "labuser" account (57 total)

```
DeviceLoginEvents
```

```
| where DeviceName == "windows-target-1"
```

```
| where LogonType == "Network"
```

```
| where ActionType == "LogonSuccess"
```

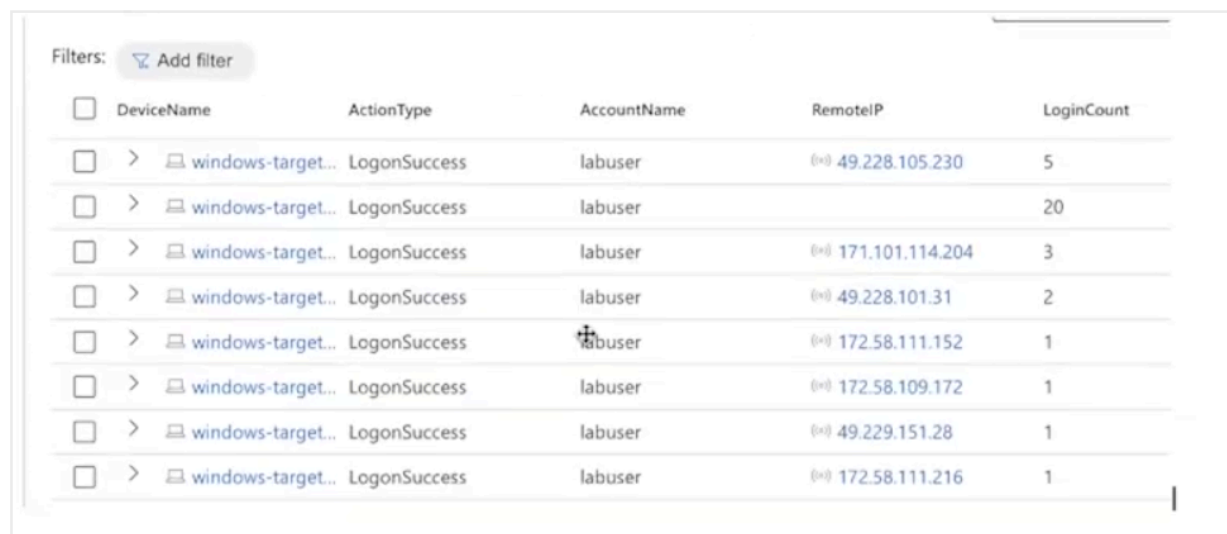
```
| where ActionName == "labuser"
| where count ()
```

There were zero (0) failed logons for the "labuser" account indicating that a brute force attempt for this account didn't take place, and a 1-time password guess is unlikely.

```
DeviceLoginEvents
| where DeviceName == "windows-target-1"
| where LogonType == "Network"
| where ActionType == "LogonFailed"
| where Action Name == "labuser"
| where count ()
```

We checked all of the successful login IP addresses for the "labuser" account to see if any of them were unusual or from an unexpected location. All were normal.

```
DeviceLoginEvents
| where DeviceName == "windows-target-1"
| where LogonType == "Network"
| where ActionType == "LogonSuccess"
| where ActionName == "labuser"
| summarize Login Count = count() by DeviceName, ActionType, AccountName,
RemoteIP
```



The screenshot shows a table of security events with the following columns: DeviceName, ActionType, AccountName, RemoteIP, and LoginCount. The table contains 8 rows of data, all for 'LogonSuccess' events for the 'labuser' account. The RemoteIP addresses are: 49.228.105.230, 171.101.114.204, 49.228.101.31, 172.58.111.152, 172.58.109.172, 49.229.151.28, and 172.58.111.216. The LoginCount values are 5, 20, 3, 2, 1, 1, and 1 respectively.

DeviceName	ActionType	AccountName	RemoteIP	LoginCount
windows-target...	LogonSuccess	labuser	49.228.105.230	5
windows-target...	LogonSuccess	labuser		20
windows-target...	LogonSuccess	labuser	171.101.114.204	3
windows-target...	LogonSuccess	labuser	49.228.101.31	2
windows-target...	LogonSuccess	labuser	172.58.111.152	1
windows-target...	LogonSuccess	labuser	172.58.109.172	1
windows-target...	LogonSuccess	labuser	49.229.151.28	1
windows-target...	LogonSuccess	labuser	172.58.111.216	1

Though the device was exposed to the internet and clear brute force attempts have taken place, there is no evidence of any brute force success or

unauthorized access from the legitimate account "labuser"

USING CHATGPT

Please observe the notes from my incident and let me know which TTPs from the MITRE ATT&CK Framework these correspond to. Please output very succinctly in code block (markdown)

Notes: (copy and paste Timeline and Summary into ChapGPT):

Relevant MITRE ATT&CK TTPs:

- T1190: Exploit Public-Facing Application (due to the internet-facing nature of the machine)
- T1078: Valid Accounts (successful logons by legitimate account 'labuser')
- T1110: Brute Force (failed logon attempts from multiple IP addresses)
- T1587.001: Develop Capabilities: Exploit Code (indirect inference from multiple bad actors attempting to log in)

Response Actions:

1. Hardened the NSG attached to windows-target-1 to allow only RDP traffic from specific endpoints (no public internet access).
2. Implement account lockout policy
3. Implement MFA